

Multi-Account (Multi-Tenant) Support — Research & Planning

Revision: 2 **Last modified:** 2026-07-10T11:18:54Z **Status:** as-is
discovery COMPLETE (10/11/12 landed); to-be design phase next —
planning only, implementation gated on operator approval **Authority:**
operator mandate 2026-07-10 (BACKGROUND research directive) **Scope**
owner: Helix OTA control plane (server/) + owned submodules + all
client surfaces

1. Mandate (verbatim intent)

Extend one hosted Helix OTA System instance so a single deployment serves **multiple clients (accounts)**. Requirements captured from the operator directive (2026-07-10):

1. **Multi-tenant.** One hosted instance $\Rightarrow$ many accounts.
2. **Account creation is super-admin-only** (the System owner). At this stage there is **no registration wizard** for new accounts or users.
3. **Users belong to one OR more accounts.**
4. **Super-user (super-admin)** sees and controls everything.
5. **All UI/UX + web dashboard + every client app** extended to support: super-user sign-in, user sign-in, and **account selection after sign-in.**
6. **Super-admin administers** all accounts, all users, and permissions (who can access / do what) — “ultimate flexibility to the maximum.”
7. **In-depth research required** (this document set).
8. **UI/UX** for every application/client/dashboard/util to be built with **OpenCode** (**▲ OPEN QUESTION** — see §5; the constitution mandates the OpenDesign design-token system §11.4.162, and docs/research/opendesign_* shows OpenDesign+shadcn already in use — this doc set will resolve whether “OpenCode” means the OpenCode coding agent, OpenDesign, or a distinct tool).
9. **Project-side integration CLI** (credentials $\rightarrow$ one account + a project under it $\rightarrow$ upload created OTA updates). “Proper

mechanisms MUST already exist” → **catalogue-first discovery required (§11.4.74)** before proposing extensions; extend to production + full test coverage.

10. **Device/System-side update client** — contacts the configured Helix OTA system, receives new-OTA-update notifications, informs users of a new System version via a **setup wizard**. “We have it already most likely” → catalogue-first discovery required.
11. Everything: cutting-edge, fully tested/validated/verified/ documented, incorporated, **no bluff of any kind** (§11.4 covenant).

2. Honest boundary (§11.4.6)

This deliverable is **research + planning only**. It produces evidence-grounded “as-is” audits and a “to-be” design + delivery plan. **No production code is written under this directive** until the operator approves the plan (superpowers brainstorming hard-gate). Every “as-is” claim cites a `file:line` read from the codebase — never an assumption that a mechanism exists.

3. Document set

As-is (grounded discovery — §11.4.74 catalogue-first, §11.4.6 evidence-only)

- `10_existing_auth_and_project_model.md` — current authN/authZ, token model, user/identity concept, the existing **project** concept, audit, the store.Repository persistence seam; where a **tenant/account layer would attach**.
- `11_existing_upload_and_device_update.md` — the project-side OTA **upload** path (CLI/API) and the device/System-side **update-check + notification + setup-wizard** mechanism, across `server/` and owned `ota-*` submodules.
- `12_existing_ui_surfaces_and_design_system.md` — every client app + the web dashboard, their sign-in flows, and the **design system actually in use** (OpenDesign / shadcn / other) — resolves the §5 OpenCode question.

To-be (design — authored after as-is lands, external research per §11.4.8/§11.4.99)

- 20_target_multitenancy_data_model.md — account / user / membership / role entities; how they scope the existing project + rollout + artifact model; store.Repository extension (in-memory MVP → pgx/PostgreSQL target).
- 21_authz_rbac_superadmin.md — super-admin, sign-in, account selection, the permission model (max flexibility: roles/permissions/scopes), token scoping to (account, project).
- 22_api_surface.md — server API extensions: account-scoped endpoints, super-admin admin API, account+project-scoped credentials for the project CLI.
- 23_ui_ux_all_surfaces.md — dashboard + client apps: sign-in, account switcher, super-admin console; OpenDesign tokens (§11.4.162) + host-rendered visual proof (§11.4.170).
- 24_project_side_cli.md — production project-integration CLI (auth → account/project → upload OTA), built by extending the discovered mechanism.
- 25_device_side_update_client.md — production update-check/notify + setup wizard, built by extending the discovered mechanism.
- 26_security_threat_model.md — tenant isolation, credential handling (§11.4.10), the artifact-signature trust boundary (server-config-only key), cross-account leakage prevention.
- 27_test_strategy.md — every applicable test type (§11.4.27/§11.4.169) with anti-bluff captured evidence per surface; per-tenant isolation tests.

Delivery

- 30_delivery_plan.md — phased plan as an isolated big-feature work-stream (§11.4.167), milestones, risks, danger zones, production-readiness (§11.4.172).

4. Grounding already captured (this session, §11.4.6)

- server/internal/ packages: api config device deviceemu fabric health rollout store transport — **no account/tenant package exists yet.**

- Tenancy-adjacent existing surfaces (grep hits): `handlers_project.go`, `token.go`, `handlers_audit.go`, `handlers_deployment.go`, `store/store.go` → a **project** concept, a **token** model, and **audit** already exist; the account layer sits **above** project (account → projects → OTA updates).

5. Open questions (resolve during research; §11.4.66 — surface, don't guess)

- ****OQ-1 “OpenCode” vs OpenDesign (§11.4.162) — RESOLVED (12_*, evidence-based).** “**OpenCode**” (3299 hits) exists **ONLY** in **submodules/llm_orchestrator + submodules/vision_engine as an LLM coding-agent adapter (opencode_agent.go, beside junie/gemini/claudecode/qwencode)** — zero hits in any UI directory. OpenCode = a coding agent used to BUILD UI; OpenDesign = the mandated design-token system (§11.4.162) the built UI must CONSUME** (already vendored into both SPAs as design-systems/helix-ota/od-design-system-project/v1 tokens). Both true. Flagged for operator confirmation per §11.4.66 only because the mandate used the literal word “OpenCode” — no blocker.
- **OQ-2 Permission model shape.** “Ultimate flexibility” → RBAC vs ABAC vs role+scope hybrid. 21_* proposes options with tradeoffs for operator choice.
- **OQ-3 Identity source.** Local accounts only, or federated (OIDC/SAML)? Directive implies local super-admin-provisioned users for now.
- **OQ-4 Account-scoping of existing data.** Are existing projects/rollouts/artifacts migrated under a default account, or is the schema additive with a nullable account until backfill? 20_* + 30_* decide the migration path.

6. Provenance

Every “as-is” doc lists the exact files+lines it read. Every “to-be” doc that cites an external best practice carries a `## Sources verified <date>` footer per §11.4.99. Nothing in this set is a §11.4 PASS-bluff: a claim of “mechanism exists” without a `file:line` is forbidden.

7. Discovery findings — as-is state (COMPLETE; details in 10/11/12)

The three grounded audits establish the starting point the to-be design builds on:

- **Auth EXISTS and is more than API-tokens.** POST /api/v1/auth/login + /auth/refresh are wired; tokens are HMAC-SHA256 signed-opaque (JWT-shaped, not real JWTs); the signing secret comes only from config/env (§11.4.10-clean). Both UI SPAs already have login + session + RBAC, **including a super_admin role and per-project ProjectAccess{project_id, role}** (10_, 12_).
- **THE central gap — no tenant isolation.** There is **no account/org/tenant entity anywhere**, and Device/Artifact/Release/Deployment/Telemetry/Group carry **no ProjectID** — so the account → projects → OTA updates hierarchy's project → resource link is entirely absent, and every OTA route is gated only by the GLOBAL RBAC role, not by data-level scoping (10_*). The Project+ProjectAccess model exists but is a parallel construct not wired into the OTA data model — the primary extension seam.
- **No persisted User entity** — identity is the token Subject; the user directory is an in-memory env-seeded map. The design-target migration already declares users+api_keys tables (unimplemented) (10_*).
- **Upload EXISTS but single-tenant.** POST /artifacts/upload runs a real S1–S6 multipart validation pipeline; /releases + /deployments publish/ deploy — none project-scoped. **No upload CLI/SDK**; the only client is the ota-manager SPA (its project-switcher is a MOCK). Artifact bytes are validated then **discarded** (StorageRef placeholder — no real object storage in-repo) (11_*).
- **Device client EXISTS** = ota-android-agent, a headless 15-min-poll WorkManager worker hitting GET /client/update, device identified only by its bearer-token subject. **No push/notification, no setup/consent wizard** — both absent (11_*).
- **UI = 2 React SPAs.** dashboard/ (Vite, hand-rolled ui.tsx, 58 hardcoded hex — PARTIAL token adoption) and clients/ota-manager/ (React 19 + shadcn + Tailwind 4 + Tauri v2, embedded at server /manager — ADOPTED OpenDesign tokens). Android agent + bridge are headless. The OTA-Manager project-switcher.tsx + use-projects.ts + ProjectAccess is the exact seam an **account-switcher** extends (account above project) (12_*).

- **Trust boundary for per-account keys:** `resolvePublicKey` takes the artifact verify key ONLY from a single global `HELIX_ARTIFACT_PUBKEY` config — the seam for per-account key scoping (11_*).

Design-phase implication: the account layer is primarily a *data-model* + *scoping* effort (add `account/user/membership` + `account_id/project_id` columns + scope every OTA resource + token `account-claim`), NOT a from-scratch auth build — auth, RBAC, `super_admin`, and both sign-in UIs already exist. Divergence to reconcile in 21_*: the dashboard's Role union omits the `super_admin` the OTA Manager already defines.